

LEARNING RESOURCE GUIDE
ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional
Participant Workbook

Operational Standards: Part 2 — CIS Controls, COSO, ITIL and ISO 20000

1. Learning Objectives

By the end of this lecture, you will be able to:

- Describe the CIS Controls Version 8 structure and explain the three Implementation Groups and their intended audiences.
- Distinguish between CIS Controls (management framework) and CIS Benchmarks (technical hardening guidance) and relate them to ISO 27001.
- Explain the COSO internal control components and identify when COSO is the correct framework to reference in exam scenarios involving financial governance and SOX compliance.
- Describe the ITIL 4 service value system, its six value chain activities, and the ITIL management practices most relevant to cloud security operations.
- Differentiate between ITIL (best-practice framework) and ISO/IEC 20000-1 (certifiable IT service management standard) using the same logic as ISO 27001 vs. ISO 27002.

2. Introduction

A mid-sized financial technology company is preparing for its annual security audit. Its security team has implemented dozens of technical controls across its AWS and Azure environments, and the compliance team has completed a SOX readiness review. But the company's largest customer — a regional bank — has asked for evidence that the company's cloud services are delivered under a formal service management system that has been independently certified. The company realizes it has three different governance problems: how to prioritize its technical controls given limited resources, how to demonstrate IT service management maturity to its customers, and how to show its auditors that cloud risks are embedded in the enterprise risk management structure.

These three problems point to three different frameworks — CIS Controls for technical prioritization, ISO 20000-1 for service management certification, and COSO for enterprise risk integration. None of these frameworks competes with the others. Each occupies a distinct layer of the governance and operations stack, and a mature cloud security program draws on all of them.

Part 2 completes the operational standards landscape introduced in Part 1. Where Part 1 covered NIST, ISO 27001/27002, and COBIT, this lecture examines four more frameworks that frequently appear in CCSP exam scenarios: CIS Controls, COSO, ITIL, and ISO 20000-1.

The matching skill — knowing which framework to select for a given scenario description — is what the exam tests, and this lecture builds the reference points for each of the four.

3. Core Concepts Explained

3.1 CIS Controls Version 8

Definition: The CIS Controls, developed by the Center for Internet Security, are an ordered set of eighteen actionable safeguards designed to defend against the most prevalent cyber-attacks. Version 8, published in 2021, consolidates and reorganizes the prior version into eighteen controls covering asset inventory, data protection, vulnerability management, secure configuration, account management, and audit log management, among others.

Business Relevance: The CIS Controls are the most implementation-focused framework in the cloud security landscape. Unlike governance frameworks that define what an organization should do at a strategic level, CIS Controls define specific safeguards that can be assigned, implemented, and tracked. The Implementation Group concept makes them scalable: small organizations with limited resources start at IG1 (essential cyber hygiene), mid-size organizations with dedicated security staff adopt IG2, and mature organizations with high-risk profiles implement the complete IG3 set.

Practitioner Angle: CIS Benchmarks are the technical complement to CIS Controls. Where the Controls define the safeguards at a management level, Benchmarks provide prescriptive configuration settings for specific platforms — AWS Foundations Benchmark, Azure CIS Benchmark, Google Cloud Platform Benchmark, Kubernetes, and many others. A security engineer applying a CIS Benchmark to an AWS account is implementing the technical settings that satisfy the relevant CIS Controls for that platform. The two documents are designed to work together.

Real-World Example: After a series of cloud misconfiguration incidents in 2019, Capital One implemented the CIS AWS Foundations Benchmark as part of its remediation program. The benchmark's specific rules — disabling public S3 bucket access, requiring MFA on root accounts, enabling CloudTrail logging across all regions — map directly to CIS Controls for secure configuration and audit log management. Applying the benchmark gave the security team a concrete, auditable checklist of configuration requirements rather than a general control objective.

Risks: Treating CIS Benchmarks as a substitute for a security program rather than one component of it. Failing to prioritize Implementation Groups appropriately — an IG1 organization attempting IG3 controls will spread resources too thin. Confusing CIS Controls with ISO 27001: CIS gives you a technical implementation toolkit; ISO 27001 gives you a certifiable management system.

3.2 COSO Internal Control Framework and ERM

Definition: COSO (Committee of Sponsoring Organizations of the Treadway Commission) produced two widely adopted frameworks: the Internal Control Integrated Framework and

the Enterprise Risk Management (ERM) Framework. The Internal Control framework defines five components: Control Environment, Risk Assessment, Control Activities, Information and Communication, and Monitoring Activities. The ERM framework integrates risk management into strategy and business performance decisions.

Business Relevance: COSO is the framework that ties IT and cloud risk management into the broader enterprise governance and financial reporting structure. For publicly traded companies subject to the Sarbanes-Oxley Act, management must attest that internal controls over financial reporting are effective, typically using the COSO framework as the reference model for that assessment. Cloud systems that process financial data or support financial reporting processes fall directly within COSO's scope.

Practitioner Angle: Cloud security professionals encounter COSO most often when working with internal audit teams conducting SOX-related assessments. The Control Environment component — covering organizational tone at the top, governance structures, and ethical standards — is frequently the focal point when auditors evaluate whether cloud risk management is integrated into the organization's overall governance framework rather than siloed in the IT department.

Real-World Example: Following the Enron and WorldCom accounting scandals, the Sarbanes-Oxley Act of 2002 required public companies to use the COSO Internal Control framework (or an equivalent) as the basis for their annual management assessment of internal control over financial reporting (ICFR). The SEC accepted COSO as the primary reference framework. Today, every major public company's SOX program references COSO, and cloud systems supporting financial processes are assessed within that framework's Control Activities and Monitoring components.

Risks: Treating COSO as a security-specific framework — it governs all enterprise internal controls including financial, operational, and IT. Failing to connect cloud risk assessments to the broader COSO Risk Assessment component, which requires risks to financial reporting to be identified and addressed at the enterprise level.

3.3 ITIL 4 — IT Service Management

Definition: ITIL (IT Infrastructure Library) is the most widely adopted IT service management framework. ITIL 4 describes a Service Value System (SVS) centered on a service value chain with six activities: Plan, Improve, Engage, Design and Transition, Obtain and Build, and Deliver and Support. Supporting the chain are thirty-four management practices organized into general, service, and technical management categories.

Business Relevance: ITIL's language is the standard vocabulary of enterprise IT service delivery. Cloud services are IT services, and cloud security operations are embedded in a broader service management context. Incident management, problem management, change enablement, service level management, and continual improvement are not just ITIL terms — they are the operational processes that govern how cloud services behave day to day, and how failures are detected, resolved, and prevented.

Practitioner Angle: The ITIL practices most directly relevant to cloud security include: change enablement (controlling changes to cloud infrastructure), incident management (restoring disrupted cloud services), problem management (eliminating recurring cloud incidents), service level management (meeting SLA commitments), and continual improvement practice (systematically improving cloud service performance). A cloud security professional who understands ITIL vocabulary can operate effectively alongside service management teams and translate security requirements into service management terms.

Real-World Example: When a major cloud provider like AWS experiences a regional outage, its internal response follows a structured incident management process — classification by severity, engagement of on-call engineering teams, status communication through the service health dashboard, escalation through defined chains, and post-incident review. The public-facing status page and post-incident reports are the customer-visible artifact of an ITIL incident management process. The subsequent root cause analysis and architectural remediation feed the problem management and continual improvement practices.

Risks: Confusing ITIL (a best-practice framework) with ISO 20000-1 (the certifiable standard) — they address the same domain but at different levels of formality. Assuming that ITIL certification of individual practitioners equates to organizational certification of service management processes — only ISO 20000-1 certifies the organization.

3.4 ISO/IEC 20000-1 — IT Service Management Standard

Definition: ISO/IEC 20000-1 is the international standard defining the requirements for a Service Management System (SMS). It follows the Plan-Do-Check-Act lifecycle, mirroring the structure of ISO 27001, and covers service delivery requirements including service level management, capacity management, availability management, information security management within the service context, and incident and problem management. Organizations can be independently certified against ISO 20000-1.

Business Relevance: ISO 20000-1 certification is the SMS equivalent of ISO 27001 certification. When a CSP holds ISO 20000-1 certification, it is signaling that its service management processes — not just its security controls — have been independently verified against an international standard. This is increasingly required in enterprise procurement and regulated industries where customers need assurance that the service management lifecycle governing a cloud service meets a recognized baseline.

Practitioner Angle: The exam-critical distinction is the same as ISO 27001 vs. ISO 27002, or COBIT vs. NIST: ITIL is a framework of best practices you implement; ISO 20000-1 is a standard you certify against. An organization implementing ITIL practices is not automatically ISO 20000-1 certified. Certification requires an independent audit by an accredited body that verifies the SMS meets the standard's requirements.

Real-World Example: Several major managed service providers and large CSPs, including IBM and Fujitsu, hold ISO 20000-1 certifications covering their service management

systems. The certification is used as a differentiator in enterprise and government procurement, where customers require evidence of formal service management beyond service level agreements alone. The certification audit covers the complete SMS lifecycle: planning, service design, transition, delivery, and continual improvement.

Risks: Assuming ISO 20000-1 replaces ITIL adoption — ISO 20000-1 does not specify which practices to implement; ITIL provides the practice content. Failing to recognize that ISO 20000-1 covers information security within the service context but does not replace ISO 27001, which governs the organization-wide ISMS.

4. Framework Comparison Table

Framework	Category	Certifiable?	Primary Use Case	CCSP Exam Trigger Words
CIS Controls v8	Technical safeguards toolkit	No	Prioritized, actionable security controls; Implementation Groups	Actionable controls, cyber hygiene, IG1/IG2/IG3
CIS Benchmarks	Platform hardening guidance	No	Prescriptive configuration settings for specific platforms	AWS/Azure/GCP hardening, configuration baseline
COSO	Enterprise internal controls / ERM	No	Financial reporting controls, SOX compliance, board risk governance	SOX, financial reporting, enterprise risk, internal controls
ITIL 4	IT service management best practices	Individual certifications only	Service delivery vocabulary, incident/problem/change management	Service management, SLA, incident, problem, CSI
ISO/IEC 20000-1	IT service management standard	Yes (organizational)	Certifiable SMS; independent verification of service processes	Certified service management, SMS, ITSM certification

5. Real-World Incident

Case Study: In 2019, Capital One experienced a breach affecting over 100 million customers when a misconfigured Web Application Firewall allowed an attacker to access AWS S3 buckets storing sensitive application data. Subsequent analysis by regulators and the bank's own post-incident review identified specific CIS Controls failures: CIS Control 4 (Secure Configuration

of Enterprise Assets) had not been applied with sufficient rigor — the WAF configuration had never been validated against the CIS AWS Foundations Benchmark. CIS Control 8 (Audit Log Management) gaps meant the abnormal data access pattern went undetected for months. The breach is a direct illustration of what happens when CIS Controls and Benchmarks are treated as optional guidance rather than operational requirements. Capital One's subsequent remediation program placed CIS Benchmark compliance at the center of its cloud configuration governance.

6. Memory Anchor

Think of the ITIL and ISO 20000-1 relationship exactly like a professional chef and a Michelin inspection. The chef follows culinary best practices — knife skills, sourcing, plating — developed through years of training and guides like ITIL. The Michelin inspector does not care which culinary school the chef attended; the inspector assesses whether the restaurant's food, service, and environment actually meet the published standard right now, consistently. That assessment is the ISO 20000-1 certification. The chef can keep all their best-practice guides; the star on the door comes from the independent inspection. Similarly, an organization can implement ITIL thoroughly without being ISO 20000-1 certified, but the certification requires a third party to verify the service management system is functioning as described.

7. Exam Focus

The four frameworks in this lecture each have a distinct exam trigger profile. CIS Controls appear when a scenario involves prioritizing security safeguards, particularly for organizations with limited resources, or when the question mentions Implementation Groups. CIS Benchmarks appear when a scenario involves platform-specific configuration hardening.

COSO scenarios involve financial reporting, SOX compliance, board-level risk governance, or internal controls that span financial and IT functions. When you see 'Sarbanes-Oxley,' 'internal controls over financial reporting,' or 'board risk appetite,' the answer involves COSO or a reference to its components.

ITIL scenarios involve service management vocabulary: incident management, problem management, service level agreements, service catalogs, mean time to restore, or the service value chain. When a scenario asks about restoring a disrupted cloud service quickly, the ITIL incident management practice is the reference.

ISO 20000-1 scenarios specifically involve organizational certification of a service management system, or distinguishing between a framework and a certifiable standard for service management. The key distractor is selecting ITIL — ITIL is not certifiable at the organizational level; ISO 20000-1 is.

Common exam traps to avoid: selecting CIS Controls when a scenario asks for a certifiable standard (CIS Controls are not certifiable); selecting ITIL when a scenario asks which

standard a CSP can be certified against for service management (ISO 20000-1 is the answer); and confusing COSO with COBIT — both have governance dimensions, but COSO is for enterprise internal controls including financial reporting, while COBIT is specifically for IT governance alignment with business objectives.

8. Key Terms Glossary

- **CIS Controls:** Center for Internet Security's ordered set of 18 actionable safeguards prioritized against common cyber-attacks.
- **Implementation Group (IG):** CIS Controls tiering: IG1 = essential cyber hygiene (small organizations), IG2 = moderate risk organizations, IG3 = mature high-risk organizations.
- **CIS Benchmarks:** Prescriptive, platform-specific configuration hardening guides aligned with CIS Controls — available for AWS, Azure, GCP, Kubernetes, and more.
- **COSO:** Committee of Sponsoring Organizations framework for internal controls (5 components) and enterprise risk management, used as the basis for SOX compliance.
- **SOX (Sarbanes-Oxley Act):** US legislation requiring public companies to document and attest to the effectiveness of internal controls over financial reporting.
- **Control Environment:** The COSO component covering tone at the top, governance structures, ethical standards, and the foundation of the internal control system.
- **ITIL 4:** IT service management best-practice framework describing a Service Value System with a service value chain and 34 management practices.
- **Service Value Chain:** ITIL 4's six interconnected activities (Plan, Improve, Engage, Design and Transition, Obtain and Build, Deliver and Support) that transform demand into value.
- **ISO/IEC 20000-1:** Certifiable international standard for IT Service Management Systems (SMS); organizational equivalent of ISO 27001 for service management.
- **Service Management System (SMS):** The ISO 20000-1-defined management system that governs design, delivery, and improvement of IT services.
- **Continual Improvement Practice:** ITIL's ongoing discipline of using metrics and learning from service performance to systematically improve services over time.
- **Mean Time to Restore (MTTR):** The average time taken to restore a service after an incident — a key ITIL service level metric.

9. Quick Revision Checklist

- ☐ I can describe the CIS Controls Version 8 structure and name the three Implementation Groups with their target audience.
- ☐ I can explain the relationship between CIS Controls and CIS Benchmarks — controls define the what; benchmarks provide the platform-specific how.
- ☐ I can name the five COSO Internal Control components: Control Environment, Risk Assessment, Control Activities, Information and Communication, Monitoring Activities.
- ☐ I know that COSO is the framework referenced for SOX compliance and enterprise risk integration with financial reporting.

- ☐ I can describe the ITIL 4 Service Value System and its six service value chain activities.
- ☐ I can name the five ITIL practices most relevant to cloud security operations.
- ☐ I understand that ITIL is a best-practice framework (not certifiable at organizational level) while ISO 20000-1 is the certifiable SMS standard.
- ☐ I can apply the ITIL/ISO 20000-1 distinction using the same logic as ISO 27001 (certifiable) vs. ISO 27002 (guidance).
- ☐ I can match each of the four frameworks to the correct CCSP exam scenario type.
- ☐ I know the common exam distractors: CIS Controls vs. ISO 27001, ITIL vs. ISO 20000-1, COSO vs. COBIT.

10. Practice Questions

Question 1 (Scenario)

A cloud-native startup with fifteen employees and no dedicated security team is trying to establish a basic security program. Their security advisor recommends starting with a specific subset of controls rather than implementing a full security framework. Which framework and grouping is most appropriate for this organization?

A. ISO/IEC 27001 with full ISMS implementation

Explanation: Incorrect. ISO 27001 requires a full management system including documented policies, internal audits, and management review. For a 15-person startup with no dedicated security staff, this is disproportionate to the organization's size and risk profile.

B. CIS Controls Version 8 — Implementation Group 1

Explanation: Correct. IG1 is the essential cyber hygiene baseline designed for small organizations with limited IT resources and no dedicated security team. It contains the minimum safeguards suitable for defending against the most common attacks without overwhelming a small team.

C. NIST SP 800-53 at the Low impact baseline

Explanation: Incorrect. While the Low baseline is NIST 800-53's minimal tier, 800-53 is designed for federal information systems and does not include the Implementation Group concept that makes CIS Controls scalable for small businesses.

D. CIS Controls Version 8 — Implementation Group 3

Explanation: Incorrect. IG3 is the complete control set designed for mature security programs with dedicated security teams and high-risk profiles. Applying it to a 15-person startup with no security staff would be impractical and resource-prohibitive.

Question 2 (Scenario)

During an external audit, the auditors ask the CISO of a publicly traded software company to demonstrate that the company's cloud-based financial reporting systems are covered by an enterprise internal control framework that management has assessed and attested to for the purposes of the annual SEC filing. The CISO must identify the framework that governs this assessment. Which framework is the auditor referencing?

A. COBIT 2019

Explanation: Incorrect. COBIT is an IT governance framework that aligns IT management with business objectives. While it overlaps with enterprise risk management, it is not the framework that management uses to assess and attest to internal controls over financial reporting for SEC filings.

B. NIST Cybersecurity Framework

Explanation: Incorrect. The NIST CSF addresses cybersecurity risk lifecycle management. It is not the framework referenced for management attestation of internal controls over financial reporting under the Sarbanes-Oxley Act.

C. COSO Internal Control Integrated Framework

Explanation: Correct. COSO is the framework adopted by the SEC for management's assessment of internal controls over financial reporting as required by SOX Section 404. Management attests annually to the effectiveness of ICFR using COSO's five components as the evaluation structure.

D. ISO/IEC 27001

Explanation: Incorrect. ISO 27001 governs the information security management system. While it addresses controls relevant to data integrity, it is not the framework used for SOX management attestation on internal controls over financial reporting.

Question 3 (Scenario)

A managed cloud services provider is responding to an enterprise RFP that requires evidence of independently certified IT service management processes. The RFP states that the provider must demonstrate that its service delivery lifecycle — including incident management, change management, and continual improvement — has been assessed by an accredited third party and found to meet an international standard. Which certification should the provider reference?

A. ITIL 4 Foundation certification

Explanation: Incorrect. ITIL Foundation is an individual practitioner certification, not an organizational certification. Holding ITIL-certified staff does not mean the organization's service management system has been independently certified against a standard.

B. ISO/IEC 27001 certification

Explanation: Incorrect. ISO 27001 certifies the organization's information security management system. It addresses security controls, not the broader IT service management system covering incident, change, and continual improvement processes that the RFP requires.

C. ISO/IEC 20000-1 certification

Explanation: Correct. ISO 20000-1 is the certifiable international standard for IT Service Management Systems. Certification by an accredited body confirms that the organization's service management processes — including incident management, change management, and continual improvement — meet international requirements.

D. SOC 2 Type II report

Explanation: Incorrect. SOC 2 is a reporting framework for service organizations covering security, availability, processing integrity, confidentiality, and privacy trust service criteria. It is not an IT service management certification and does not specifically certify the service management lifecycle processes the RFP describes.

Question 4

What is the primary distinction between CIS Controls and CIS Benchmarks?

A. CIS Controls are certifiable; CIS Benchmarks are not.

Explanation: Incorrect. Neither CIS Controls nor CIS Benchmarks are certifiable standards that organizations can be assessed against by an accredited body. Both are voluntary implementation guidance documents.

B. CIS Controls define management-level safeguards; CIS Benchmarks provide prescriptive platform-specific configuration settings.

Explanation: Correct. CIS Controls define the what — the safeguards an organization should have in place. CIS Benchmarks define the how — specific configuration settings for platforms like AWS, Azure, Kubernetes — that implement the relevant controls.

C. CIS Controls apply to cloud environments; CIS Benchmarks apply to on-premises environments.

Explanation: Incorrect. Both CIS Controls and CIS Benchmarks apply to cloud and on-premises environments. CIS Benchmarks are available for major cloud platforms including AWS, Azure, and GCP.

D. CIS Benchmarks replace CIS Controls for organizations that have already achieved ISO 27001 certification.

Explanation: Incorrect. CIS Benchmarks are not a replacement for CIS Controls in any context. They are complementary documents — controls set the objectives, benchmarks provide the implementation details. ISO 27001 certification is a separate matter.

Question 5

Which COSO Internal Control component addresses the overall culture, governance structures, and tone set by leadership that underpin the effectiveness of all other control components?

A. Control Activities

Explanation: Incorrect. Control Activities are the specific actions and policies that help management directives are carried out — such as approvals, authorizations, reconciliations. They are not the foundational cultural component.

B. Risk Assessment

Explanation: Incorrect. Risk Assessment involves identifying and analyzing risks to achieving objectives. It is a specific component, not the foundational governance and culture component.

C. Control Environment

Explanation: Correct. The Control Environment is the foundation of the COSO framework, encompassing the tone at the top, ethical values, governance structures, and organizational culture. It sets the context within which all other components operate.

D. Monitoring Activities

Explanation: Incorrect. Monitoring Activities involve ongoing evaluations of whether controls are present and functioning. They assess the effectiveness of the other components but are not the foundational governance layer.

Question 6

In the ITIL 4 Service Value System, which activity is responsible for ensuring that services and products continually meet stakeholder expectations?

A. Obtain and Build

Explanation: Incorrect. Obtain and Build is the service value chain activity that ensures service components are available when and where they are needed. It does not specifically focus on continual stakeholder expectation management.

B. Improve

Explanation: Correct. The Improve activity ensures that all four dimensions of service management and all products and services are continually improved. It is the value chain

activity dedicated to driving ongoing performance and quality enhancement against stakeholder expectations.

C. Engage

Explanation: Incorrect. Engage is the value chain activity that provides a good understanding of stakeholder needs, transparency, and continual engagement. While related, Engage focuses on stakeholder relationships and demand understanding, not the continual improvement of services and products.

D. Design and Transition

Explanation: Incorrect. Design and Transition ensures that products and services meet stakeholder quality, cost, and time-to-market expectations — but as a transition activity for new or changed services, not as a continual improvement mechanism.

Question 7

A CSP has invested heavily in training all its service management staff to ITIL 4 Practitioner level and has documented its service management processes following ITIL best practices. A prospective enterprise customer asks for evidence that the CSP's service management system has been independently certified. Which statement is accurate?

A. The CSP can reference its ITIL-certified staff as equivalent to organizational certification.

Explanation: Incorrect. ITIL certifications are individual practitioner credentials. They do not constitute or imply organizational certification of the service management system. The customer is asking for something different.

B. The CSP must obtain ISO/IEC 20000-1 certification to satisfy the customer's request.

Explanation: Correct. ISO 20000-1 is the only internationally recognized certification for an IT Service Management System at the organizational level. ITIL adoption is the practice framework; ISO 20000-1 certification is the independent verification the customer requires.

C. Documenting processes per ITIL constitutes ISO 20000-1 compliance.

Explanation: Incorrect. ISO 20000-1 certification requires a formal audit by an accredited certification body. ITIL-aligned documentation supports readiness for that audit but is not equivalent to certification.

D. The CSP can reference its ISO 27001 certification as evidence of service management maturity.

Explanation: Incorrect. ISO 27001 certifies the information security management system, not the IT service management system. Service delivery lifecycle processes covered by ISO 20000-1 are not within the scope of ISO 27001.

Question 8

On a CCSP exam, a scenario describes an organization that must demonstrate to its board that cloud-related risks are identified, assessed, and managed within the broader enterprise risk framework, with risk appetite decisions made at the governance level. Which framework is most relevant?

A. CIS Controls Version 8

Explanation: Incorrect. CIS Controls provide actionable technical safeguards. They do not address board-level risk appetite decisions or enterprise risk governance structures.

B. COSO ERM Framework

Explanation: Correct. The COSO ERM Framework integrates risk management into strategy and business performance at the enterprise level, including board-level risk appetite governance. It is the reference framework when cloud risks must be embedded in the enterprise risk management structure and demonstrated to the board.

C. ITIL 4 Continual Improvement Practice

Explanation: Incorrect. ITIL Continual Improvement Practice addresses systematic improvement of IT services based on performance metrics. It does not govern board-level risk appetite decisions or enterprise risk management integration.

D. ISO/IEC 20000-1

Explanation: Incorrect. ISO 20000-1 certifies the IT service management system. It does not address enterprise risk management governance or board-level risk appetite structures.

Question 9

A cloud security team wants to apply prescriptive hardening to its Google Cloud Platform environment based on a recognized external standard. Which resource should they consult?

A. NIST SP 800-53 Moderate baseline

Explanation: Incorrect. NIST 800-53 provides a control catalog with impact baselines but does not provide prescriptive GCP-specific configuration settings. It describes what controls are needed, not how to configure GCP specifically.

B. CIS Google Cloud Platform Foundation Benchmark

Explanation: Correct. CIS Benchmarks provide prescriptive, platform-specific configuration settings. The CIS GCP Foundation Benchmark gives the team specific configuration requirements — account settings, network configuration, logging, monitoring — tailored to the GCP environment.

C. ISO/IEC 27002 Technological controls theme

Explanation: Incorrect. ISO 27002's technological controls provide implementation guidance at a level of abstraction that is not platform-specific. It does not provide GCP-specific configuration settings.

D. COBIT 2019 management practices

Explanation: Incorrect. COBIT management practices address governance and management at an organizational level. They do not provide platform-specific technical configuration guidance for cloud environments.

Question 10

Which pair correctly links each framework to its primary distinguishing characteristic for CCSP exam purposes?

A. COSO = certifiable IT service management; ISO 20000-1 = enterprise financial controls

Explanation: Incorrect. This reverses the two frameworks. ISO 20000-1 is certifiable for IT service management; COSO governs enterprise internal controls including financial reporting.

B. CIS Controls = board-level governance; COBIT = technical hardening

Explanation: Incorrect. This also reverses the frameworks. CIS Controls provide technical hardening guidance; COBIT is the board-level IT governance framework.

C. ITIL = IT service management best practices; ISO 20000-1 = certifiable IT service management standard

Explanation: Correct. ITIL is the best-practice framework; ISO 20000-1 is the certifiable standard. This is the fundamental distinction the exam tests for this pair, mirroring the ISO 27001/27002 distinction in the security domain.

D. COSO = IT governance aligned with business strategy; COBIT = financial reporting internal controls

Explanation: Incorrect. COBIT is the IT governance framework aligned with business strategy; COSO governs enterprise internal controls for financial reporting and broader risk management. This reverses both.